

SECURITY CONTROL & COMPLIANCE AUDIT
Internal IT Audit Based on NIST CSF, GDPR, PCI DSS & SOC Controls

1. Project Overview

Conducted a simulated internal IT audit for a growing retail organization operating both physical and online sales channels. The objective of the assessment was to evaluate the organization's security posture, identify governance and compliance gaps, and recommend security controls aligned with industry frameworks and regulatory requirements.

The audit focused on:

- asset management,
- Access governance,
- security control effectiveness,
- compliance readiness,
- operational resilience,
- Protection of sensitive customer data.

The assessment was performed using principles from the NIST Cybersecurity Framework (CSF) and included GDPR, PCI DSS and SOC control considerations.

2. Business context

The organization processed customer payment information and personal identifiable information (PII/SPII) through both on-site and online operations. Rapid organizational growth introduces increased exposure to:

- regulatory non-compliance,
- Weak access governance,
- Insufficient data protection measures,
- Operational disruption,
- Inadequate disaster recovery preparedness.

An internal audit was initiated to assess the company's current security controls and identify remediation priorities.

3. Scope of assessment

The audit reviewed:

- internal IT assets and infrastructure,
- user permissions and access controls,
- Technical and physical safeguards,
- Organizational policies and procedures.
- Existing security governance practices,
- Compliance obligations related to customer and payment data.

Assets evaluated included:

- employee endpoints,
- Internal networks,
- Databases,
- Ecommerce systems,
- Legacy systems,
- Physical facilities,
- Data storage and retention processes.
-

4. Risk Assessment Activities

Conducted a qualitative risk assessment to identify:

- high risk security gaps,
- Weaknesses in control implementation,
- Exposure related to unauthorized data access,
- Operational continuity risks,
- Potential regulatory and financial impact.

The organization received a high-risk score due to:

- absence of least privilege enforcement,
- lack of disaster recovery planning,
- Missing IDS capabilities,
- Inadequate encryption practices,
- Weak password governance,
- Insufficient centralized password management.

5. Controls Assessment

Evaluated administrative, technical and physical controls, including:

A) Administrative controls

- password policies,
- Access governance,
- Separation of duties.
- Privacy procedures.

B) Technical controls

- Firewalls,
- Encryption,
- Intrusion detection systems (IDS),
- Antivirus protections,
- Password management systems.

C) Physical Controls

- CCTV monitoring,
- Physical locks,
- Operational facility protections.

The assessment categorized controls according to:

- preventive,
- Detective,
- Deterrent,
- Corective functions.

6. Compliance & Governance Analysis

Reviewed organizational alignment with:

- A) NIST CSF - focused primarily on identify, protect, detect functions.
- B) GDPR - assessed protection of EU customer data, breach notification readiness, privacy governance practices, data handling procedures.
- C) PCI DSS - evaluates controls protecting payment card information, including encryption practices, access restrictions, confidentiality safeguards.

- D) SOC Controls - reviewed data confidentiality, integrity, authorized access management, operational control effectiveness.

7. Key findings

Identified several governance and security weaknesses:

- all employees had broad access to sensitive data
- Least privilege principles were not implemented
- Disaster recovery plans and backups were missing
- IDS were not deployed,
- Password complexity requirements were insufficient
- No centralized password management system existed
- Sensitive payment data lacked proper encryption safeguards
- Legacy system monitoring processes lacked formal scheduling and governance.

8. Recommendations

Recommended implementation of:

- least privilege access controls,
- Role-based access governance,
- Centralized password management,
- Stronger password complexity standards,
- Encryption for sensitive customer data,
- Disaster recovery and backup procedures,
- Intrusion detection capabilities,
- Improved asset classification and governance processes.

Additional recommendations included strengthening stakeholder communication and improving documentation related to compliance and security operations.

9. Skill demonstrated :

- IT audit,
- Risk assessment,
- Security governance,
- compliance analysis,
- NIST CSF,
- GDPR,
- PCI DSS,
- SOC Controls,
- Access control Review,
- Security controls assessment,
- Risk mitigation,
- Data protection,
- Stakeholder communication,
- Policy & procedure evaluation,
- Security documentation.

10. Outcome

The project demonstrated the ability to:

- assess organizational cybersecurity maturity,
- Identify compliance and governance gaps,
- Prioritize security risks,
- Evaluate control effectiveness,
- Communicate remediation recommendations aligned with business and regulatory requirements.